

Mona DRP — MVP Planı (Açıklamalı)

Haziran 2026 | Ağustos 2026 Deadline

1. MVP'nin Ana Amacı
2. Kapsam Ayrımı: Core / Plus / İleri Faz
3. MVP Core Feature Seti
4. MVP Plus Feature Seti
5. Demo / Mock Kapsamı
6. Asset Kavramı — Veri Modelinin Temeli
7. Veri Modeli
 - 7.1 Tablo Bazlı Açıklama
8. MVP Modül Yapısı
 - 8.1 Modül Sorumlulukları ve Çıktıları
9. Core Modül Detayları
 - 9.1 Input: Manual URL ve Permütasyon
 - 9.2 Domain Doğrulama
 - 9.3 Crawler / Page Intelligence
 - 9.4 Basic DOM Structural Similarity
 - 9.5 Logo / Favicon Similarity
 - 9.6 OCR
 - 9.7 Form / Login Detection
 - 9.8 Risk Scoring / Rule Engine
 - 9.9 Human Review
 - 9.10 Evidence Package ve Takedown Mock
10. MVP Plus Modül Detayları
 - 10.1 CT Log Feed
 - 10.2 WHOIS / Yeni Domain Feed
 - 10.3 Şikayetvar Scraping
 - 10.4 HTML Fingerprint ve Basit Recurrence
 - 10.5 LLM Risk Özeti

- 11. Düşünülen Teknik Bileşenler
- 12. Data Flow — Uçtan Uca Akış
 - 12.1 Aşama Bazlı Veri Yazımı
 - 12.2 Outbox / Actor Mantığı
- 13. MVP Dışında Bırakılanlar

Bu belge, Mona DRP için Ağustos 2026 sonuna kadar çıkarılabilecek MVP kapsamını açıklar. Önceki feature analizindeki yetenekler burada **MVP Core**, **MVP Plus** ve **Demo/Mock** olarak ayrılmıştır. Amaç, bütün ürünü bir anda yapmak değil; sahte site tespiti için temel değerini çalışan ve anlatılabilir bir pipeline ile göstermektir.

Kritik ilke: MVP dışında kalan feature'lar bu aşamada kodlanmayacak; ancak veri modeli ve modül ayrımı ileride bu feature'ları taşıyabilecek şekilde düşünülmelidir.

1. MVP'nin Ana Amacı

MVP'nin amacı, korunan bir markaya ait resmi domain/asset ile şüpheli bir domain/URL arasında benzerlik ve risk analizi yapabilen temel bir Digital Risk Protection akışı kurmaktır.

Bu MVP, gerçek ürünün tüm kanallarını kapsamaz. Sosyal medya, reklam izleme, email security, dark web, deepfake veya gelişmiş threat graph gibi konular ileri fazda ele alınacaktır. Ağustos hedefi için ana problem şu şekilde daraltılmıştır:

“Korunan bir markaya benzeyen sahte siteyi bul, siteyi güvenli şekilde incele, domain/görsel/DOM/form/OCR sinyallerini çıkar, açıklanabilir risk skoru üret, insan incelemesine sun ve aksiyon için kanıt paketi hazırla.”

MVP'nin demo senaryosu basit ve anlaşılır olmalıdır:

1. Sisteme bir marka ve resmi domain tanımlanır.
2. Test için bir orijinal site ve en az bir sahte/kopya site hazırlanır; demo güçlendirilmek istenirse iki farklı sahte varyasyon da kullanılabilir.
3. Şüpheli domain/URL sisteme aday tehdit olarak girer.
4. Sistem DNS ve HTTP erişim kontrolü yapar.
5. Harici veya izole crawler ile site açılır.
6. Screenshot, DOM, HTML, favicon ve temel metadata toplanır.
7. Domain similarity, logo/favicon similarity, basic DOM structural similarity, OCR ve form/login detection sinyalleri üretilir.
8. Rule-based risk skoru hesaplanır.
9. Human review ekranında analist sonucu inceler.
10. Evidence package ve takedown mock/log akışı gösterilir.

MVP'nin hedefi tam otomatik, tüm dünyayı tarayan bir sistem çıkarmak değildir. Hedef, ürünün ana değer önerisini gösterecek kadar çalışan bir uçtan uca akış kurmaktır.

2. Kapsam Ayrımı: Core / Plus / İleri Faz

Bu belgede üç farklı kapsam seviyesi kullanılmıştır:

Kapsam	Anlamı
MVP Core	MVP çalışsın diye kesin gerekli parçalardır. Bunlar olmadan ana demo zayıflar veya bozulur.
MVP Plus	Zaman kalırsa MVP'ye eklenebilecek parçalardır. Bunlar ileri faz değildir; MVP'yi güçlendirir ama olmazsa core demo çalışır.
Demo / Mock	Gerçek dünyadaki entegrasyonun simülasyonudur. Özellikle takedown tarafında gerçek API yerine log/mock yeterlidir.

İleri faz ise ayrı belgede tutulur. İleri faz, MVP'ye sığmayacak kadar büyük veya ürünleşme kararı gerektiren feature'ları kapsar.

3. MVP Core Feature Seti

Aşağıdaki parçalar MVP'nin temelini oluşturur. Her bir feature için kısa açıklama, çözdüğü problem ve MVP içindeki rolü ayrıca belirtilmiştir.

Feature	Ne çözer?	Neden Core?	MVP çıktısı
Protected Entity / Asset	Hangi markanın ve hangi dijital varlığın korunacağını tanımlar	Sistem domain değil asset odaklı kurulmalı	Entity + Asset kaydı
Manual URL input	Demo veya manuel inceleme için aday URL girişi sağlar	Demo akışını garanti eder	Candidate kaydı
Domain variation	Resmi domainin sahte varyasyonlarını üretir	Sahte domain tespitinin temelidir	Benzer domain adayları
DNS / HTTP kontrol	Aday domain gerçekten aktif mi, site açılıyor mu kontrol eder	Aktif olmayan adayları elemek gerekir	Erişilebilir aday listesi
Crawler	Şüpheli siteyi açıp içeriğini toplar	Domain benzerliği tek başına yeterli değildir	Screenshot, DOM, HTML, favicon
Domain similarity	Aday domainin resmi domaine ne kadar benzediğini ölçer	İlk risk sinyalidir	Benzerlik skoru
Basic DOM structural similarity	Şüpheli sayfanın DOM yapısının referans yapıya temel düzeyde benzeyip benzemediğini ölçer	Crawler zaten DOM topladığı için basit yapısal benzerlik MVP'de değerli bir sinyaldir	DOM benzerlik skoru
Logo/favicon similarity	Sahte sitenin görsel olarak markayı taklit edip etmediğini ölçer	Phishing sitelerde görsel taklit temel sinyaldir	Görsel benzerlik skoru
OCR	Görsel içine gömülmüş marka adı veya kritik metni okur	Saldırgan metni HTML yerine görsele koyabilir	OCR metni ve skoru

Feature	Ne çözer?	Neden Core?	MVP çıktısı
Form/login detection	Kullanıcı bilgisi toplayan form var mı bakar	Login/password formu yüksek phishing sinyalıdır	Form riski
Rule-based risk scoring	Tüm sinyalleri tek karara dönüştürür	Açıklanabilir verdict gerekir	clean/suspicious/malicious
Human review	Otomatik kararın insan tarafından doğrulanmasını sağlar	False positive riskini azaltır	confirmed / false_positive
Evidence package	Aksiyon ve takedown için kanıt toplar	Tespit aksiyona dönüşmelidir	Screenshot + HTML + skor + karar

4. MVP Plus Feature Seti

MVP Plus parçaları, core pipeline çalıştıktan sonra eklenebilecek güçlendirici kaynak ve yeteneklerdir. Bunlar ileri faz olarak düşünülmemelidir; yalnızca Ağustos hedefi içinde zaman kalırsa MVP'ye eklenebilir.

Feature	Ne sağlar?	Neden Plus?
CT Log Feed	Yeni SSL sertifikalarından marka adı içeren domainleri yakalar	Yararlı kaynak ama manual/permutation akışı MVP için yeterli
WHOIS / yeni domain feed	Yeni kayıtlı domainleri marka benzerliğine göre filtreler	Veri kaynağı entegrasyonu ek iş yükü getirir
Şikayetvar scraping	Kullanıcı şikayetlerinden URL/domain çıkarır	Değerli ama scraping/NLP tarafı core akışı büyütebilir
HTML fingerprint	Daha önce görülen sahte şablonları tekrar yakalar	Basit hali MVP'ye eklenebilir ama core demo için şart değildir
LLM risk özeti	Risk kararını analist için doğal dile çevirir	Faydalı ama karar motoru LLM'e bağlı olmamalı
Basit recurrence monitoring	Kaldırılan/confirmed tehdidin tekrar görülmesini izler	MVP'de sınırlı yapılabilir, gelişmiş hali Threat Graph ister

5. Demo / Mock Kapsamı

Demo tarafında amaç gerçek dünya entegrasyonlarının tamamını bitirmek değil, ürün akışının uçtan uca anlaşılmasını sağlamaktır.

Demo kapsamı:

- Bir orijinal site ve en az bir sahte/kopya site hazırlanır; gerekirse iki farklı sahte varyasyonla demo güçlendirilir.
- Şüpheli URL sisteme girilir veya permütasyonla üretilir.
- Crawler sahte siteyi açar ve kanıtları toplar.
- Analiz sinyalleri çıkarılır.

- Risk skoru ve verdict üretilir.
- Human review ekranında karar verilir.
- Takedown gerçek API ile çalışmasa bile log/mock olarak gösterilir.

Bu yaklaşım MVP'yi yönetilebilir tutar. Takedown, sosyal medya, reklam, email veya dark web entegrasyonları gerçek ürün aşamasında genişletilebilir.

6. Asset Kavramı — Veri Modelinin Temeli

Mona DRP yalnızca domain koruma sistemi gibi düşünülmemelidir. Domain/URL, korunan dijital varlık türlerinden sadece biridir. Bu nedenle temel kavram **asset** olmalıdır.

```
Protected Entity
├── Asset
│   └── Asset Type
```

Protected Entity: Korunan marka, kurum, kişi veya şirket grubudur. Örneğin Akbank, A101, Yapı Kredi gibi.

Asset: Bu entity'ye ait korunan dijital varlıktır. MVP'de ağırlıklı olarak domain/subdomain üzerinden çalışır.

Asset Type: Asset'in türünü belirtir. MVP'de domain/subdomain ana odaktır; ileri fazda logo, sosyal medya hesabı, yönetici kimliği, ses, video, mobil uygulama gibi varlık tipleri eklenebilir.

Örnek asset listesi:

Entity	Asset Type	Asset	MVP'deki rolü
Akbank	Domain	akbank.com	Ana referans domain
Akbank	Subdomain	direkt.akbank.com	Manuel eklenen resmi subdomain
Akbank	Logo Metadata	akbank_logo.png	Domain asset'inin referans görseli
A101	Domain	a101.com.tr	Ana referans domain
A101	Subdomain	kampanya.a101.com.tr	Manuel resmi subdomain
Yapı Kredi	Domain	yapikredi.com.tr	Ana referans domain

MVP'de logo ve favicon ayrı ana asset gibi ele alınmayacaktır. Bunlar domain asset'inin **metadata** alanında referans görsel olarak tutulacaktır. Böylece logo/favicon similarity yapılabilir, fakat sistemin ana koruma nesnesi hâlâ domain/subdomain olur.

7. Veri Modeli

MVP veri modeli iki amacı aynı anda karşılamalıdır:

1. Ağustos MVP'sinin temel pipeline'ını çalıştırmak.
2. İleri fazdaki yeni kaynak ve yeni asset tiplerine büyük kırılmı olmadan genişleyebilmek.

Bu nedenle bazı alanlar enum yerine string, bazı ek bilgiler ise JSONB metadata olarak tutulur.

```
-- Korunan marka / kurum / kişi
entities
  id, name, type, created_at

-- Korunan dijital varlık
assets
  id, entity_id, asset_type, value, metadata JSONB, is_active, created_at

-- Şüpheli domain / URL / kaynaklardan gelen aday tehdit
candidates
  id, entity_id, source, value, status, metadata JSONB, discovered_at

-- Adayın hangi asset'lere ne kadar benzediği
candidate_asset_matches
  id, candidate_id, asset_id, similarity_score, match_type, created_at

-- Crawler çıktısı
crawl_results
  id, candidate_id, http_status, title, has_form,
  has_password_input, brand_name_found, redirect_chain,
  dom_summary JSONB, crawled_at, storage_ref

-- Analiz sinyalleri
detection_signals
  id, candidate_id, signal_type, score, details, metadata JSONB, created_at

-- Nihai risk skoru ve karar
risk_scores
  id, candidate_id, total_score, verdict, reasons, created_at

-- İnsan inceleme kararı
reviews
  id, candidate_id, reviewer, decision, notes, reviewed_at

-- Aksiyon / vaka kaydı
cases
  id, candidate_id, status, takedown_sent_at, notes, created_at

-- Kanıt dosyalarının PostgreSQL blob/storage referansları
evidence_files
  id, case_id, file_type, storage_ref, timestamp, created_at

-- MVP'de Kafka yerine kullanılabilecek basit iş kuyruğu
outbox_jobs
  id, job_type, payload JSONB, status, retry_count, created_at, processed_at
```

7.1 Tablo Bazlı Açıklama

Aşağıdaki tablo, şemadaki tabloların MVP içindeki görevini ve hangi ileri faz genişlemelerine zemin hazırladığını özetler. Bu kısım özellikle veri modelinin sadece bugünkü demo için değil, sonraki feature'ları da taşıyabilecek şekilde neden tasarlandığını gösterir.

Tablo	MVP'deki görevi	Kritik alanlar	İleri faza katkısı
entities	Korunan marka/kurum/kişi kaydını tutar	name , type	Multi-tenant, grup şirket ve kişi koruma yapısına temel olur
assets	Korunan dijital varlıkları tutar	asset_type , value , metadata	Domain dışındaki logo, sosyal hesap, kişi, ses, video gibi asset tiplerine genişleyebilir
candidates	Şüpheli domain/URL veya kaynaklardan gelen adayları tutar	source , value , status , metadata	Email, sosyal medya, reklam, dark web gibi yeni input kaynakları aynı tabloya bağlanabilir
candidate_asset_matches	Bir adayın hangi resmi asset'e ne kadar benzediğini tutar	candidate_id , asset_id , similarity_score , match_type	Bir adayın birden fazla domain/subdomain/logo/social asset ile eşleşebilmesini sağlar
crawl_results	Crawler'ın şüpheli siteden topladığı teknik sonucu tutar	http_status , title , has_form , dom_summary , storage_ref	Basic DOM similarity, HTML fingerprint, campaign correlation gibi analizlerin ham verisini sağlar
detection_signals	Her analiz sinyalini ayrı kayıt olarak tutar	signal_type , score , details , metadata	Domain, görsel, DOM, form, OCR ve ileride graph/model sinyalleri için açıklanabilir geçmiş oluşur
risk_scores	Nihai skor, verdict ve gerekçeleri tutar	total_score , verdict , reasons	Analist önceliklendirmesi, raporlama ve blocklist entegrasyonlarına temel olur
reviews	Human review kararlarını tutar	decision , notes , reviewer	False positive azaltma, self-improving model ve rule tuning için geri besleme sağlar
cases	Aksiyon/takedown sürecini vaka olarak izler	status , takedown_sent_at , notes	Gerçek takedown entegrasyonu, lifecycle tracking ve SLA ölçümüne temel olur
evidence_files	Screenshot, HTML, DOM, OCR gibi kanıt dosyalarının path'lerini tutar	file_type , storage_ref , timestamp	Hukuki kanıt, takedown başvurusu ve recurrence monitoring için kullanılır
outbox_jobs	MVP'de Kafka yerine basit iş kuyruğu sağlar	job_type , payload , status , retry_count	İleri fazda Kafka topic'lerine geçişi kolaylaştırır

Tasarım notu: `asset_type` , `source` ve `signal_type` gibi alanlar enum yerine string tutulur. Bunun sebebi, MVP sonrası yeni asset tipi veya yeni input kaynağı geldiğinde şemayı kırmadan genişleyebilmektir. Screenshot, HTML arşivi, DOM snapshot ve OCR çıktısı gibi büyük kanıt dosyaları MVP'de PostgreSQL blob/large object veya ilgili storage extension ile

tutulur. Tablolarda dosyanın kendisine ya da saklama referansına karşılık gelen `storage_ref` alanı kullanılır. İleride aynı storage interface arkasına S3 veya harici nesne depolama implementasyonu eklenebilir.

8. MVP Modül Yapısı

MVP pipeline'ı şu modüllerden oluşur:



Bu yapı bilinçli olarak modüler tutulur. Çünkü ileride input kaynakları artabilir, risk scoring gelişebilir, takedown tarafı gerçek entegrasyonlara dönüşebilir veya Kafka tabanlı event-driven mimariye geçilebilir.

8.1 Modül Sorumlulukları ve Çıktıları

Bu tablo, şemadaki her modülün hangi işi yaptığını, hangi veriyi ürettiğini ve sonraki modüle ne aktardığını netleştirir.

Modül	Temel sorumluluk	Ürettiği çıktı	Yazdığı / kullandığı tablo
Input kaynakları	Manual URL veya permütasyonla aday üretir; Plus kaynaklar CT Log, WHOIS ve Şikayetvar olabilir	Candidate domain/URL	<code>candidates</code>
Domain doğrulama	DNS aktif mi, HTTP açılıyor mu, domain benzerliği anlamlı mı kontrol eder	Erişilebilir ve ön filtrelenmiş aday	<code>candidates</code> , <code>candidate_asset_matches</code>
Crawler	Şüpheli siteyi izole ortamda açar; screenshot, DOM, HTML, favicon ve metadata toplar	Crawl sonucu ve evidence referansı	<code>crawl_results</code> , <code>evidence_files</code> , PostgreSQL blob/storage
Analiz	Domain similarity, logo/favicon similarity, basic DOM structural similarity, OCR ve form/login detection sinyallerini hesaplar	Ayrı ayrı detection signal kayıtları	<code>detection_signals</code>
Risk scoring	Sinyalleri ağırlıklandırarak clean/suspicious/malicious verdict üretir	Risk skoru, verdict, gerekçeler	<code>risk_scores</code>
Human review	Analistin otomatik kararı doğrulamasını veya false positive işaretlemesini sağlar	İnceleme kararı	<code>reviews</code>
Takedown mock / case	Kanıt paketini case'e bağlar ve takedown talebini loglar	Case ve aksiyon kaydı	<code>cases</code> , <code>evidence_files</code>

Bu ayrımın amacı, MVP'de basit çalışan bir pipeline kurarken ileride aynı modüllerin büyüyebilmesini sağlamaktır. Örneğin input kaynakları çoğaldığında yalnızca yeni connector eklenir; risk scoring geliştiğinde detection signal yapısı korunur; Kafka'ya geçildiğinde ise modüller aynı kalır, sadece mesaj taşıma yöntemi değişir.

9. Core Modül Detayları

9.1 Input: Manual URL ve Permütasyon

MVP'de input tarafı iki şekilde çalışır.

İlk yol manual URL girişidir. Demo için şüpheli domain doğrudan sisteme girilebilir. Bu, demo akışını garanti eder ve dış veri kaynağına bağımlılığı azaltır.

İkinci yol permütasyon üretimidir. Resmi domainden harf ekleme, silme, değiştirme, homograph veya TLD değişimi gibi varyasyonlar üretilir. Örneğin `akbank.com` için `akbank-giris.com` , `akbnk.com` , `akbank-login.net` gibi adaylar oluşabilir.

Üretilen veya manuel girilen her aday **candidates** tablosuna yazılır. Böylece kaynağın manual, permutation, CT log veya Şikayetvar olması ana pipeline'ı değiştirmez.

9.2 Domain Doğrulama

Domain similarity tek başına yeterli değildir. Üretilen domainlerin büyük kısmı kayıtlı olmayabilir veya site açılmıyor olabilir. Bu yüzden doğrulama modülü önce DNS ve HTTP kontrolü yapar.

Kontrol adımları:

1. Domain DNS üzerinde çözümleniyor mu?
2. HTTP/HTTPS ile erişilebilir mi?
3. Redirect zinciri var mı?
4. Domain resmi asset'e yeterince benziyor mu?
5. Eşik altındaysa düşük risk veya elenen aday olarak işaretlenir.
6. Eşik üstündeyse crawler kuyruğuna alınır.

Bu modül false positive oranını azaltır ve crawler'ın gereksiz sayıda site açmasını engeller.

9.3 Crawler / Page Intelligence

Crawler, şüpheli siteyi gerçekten açıp içeriğini toplar. Bu aşama çok önemlidir çünkü sahte domain tespiti sadece isim benzerliğiyle yapılamaz. Bir domain markaya benzeyebilir ama zararsız olabilir; başka bir domain ise ismen çok benzemese bile içeride markanın logosunu ve login formunu kullanıyor olabilir.

Crawler çıktıları:

Çıktı	Neden gerekli?
Screenshot	Görsel kanıt, logo/OCR analizi ve human review ekranı için
DOM snapshot	Form, input, script, basic DOM structural similarity ve sayfa yapısı analizi için
HTML arşivi	Evidence package ve ileride HTML fingerprint için
Favicon	Marka favicon benzerliği ve phishing kit sinyali için
Title/body metin	Marka adı veya phishing dili için
Redirect chain	Kullanıcının nereye yönlendirildiğini görmek için
Metadata	HTTP status, SSL, WHOIS, crawl zamanı gibi ek bilgiler için

Crawler işlemi ana uygulama sunucusunda çalıştırılmamalıdır. Şüpheli siteler zararlı script, bot trap veya exploit içerebilir. Bu nedenle Browserless.io gibi harici servis veya izole Docker/VM tercih edilir.

9.4 Basic DOM Structural Similarity

MVP’de DOM tarafı yalnızca “form var mı / login input var mı?” kontrolüne indirgenmemelidir. Crawler zaten DOM snapshot topladığı için, bu veriden basit bir yapısal benzerlik sinyali üretmek MVP için mantıklıdır.

Bu feature’ın amacı gelişmiş DOM tree edit distance yapmak değildir. MVP seviyesinde hedef, şüpheli sayfanın temel yapısının referans sayfaya benzeyip benzemediğini ölçmektir. Örneğin sahte site login sayfasını kopyaladıysa sadece `input type="password"` bulunması değil, form/ input/button/link dağılımı, önemli tag’lerin kullanımı ve sayfa akışındaki temel düzen de benzer görünebilir.

MVP’de kullanılabilecek basit DOM sinyalleri:

Sinyal	Açıklama
Form sayısı	Şüpheli sayfada kaç form olduğu
Input türleri	<code>password</code> , <code>email</code> , <code>text</code> , <code>tel</code> , <code>number</code> gibi input türleri
Button / submit sayısı	Giriş veya devam aksiyonlarını gösteren butonlar
Link sayısı ve yoğunluğu	Sayfanın basit landing page mi, kopya site mi olduğunu anlamaya yardımcı olur
Önemli tag dağılımı	<code>form</code> , <code>input</code> , <code>button</code> , <code>img</code> , <code>script</code> , <code>iframe</code> gibi elemanların oranı
Title / heading benzerliği	Sayfa başlığı ve ana başlıkların referans sayfaya yakınlığı
Login alanlarının varlığı	Form detection ile birlikte risk skorunu güçlendirir

Bu sinyal `detection_signals` tablosuna `signal_type = "dom_structural_similarity"` olarak yazılabilir. Böylece MVP’de basit DOM yapısal benzerliği kullanılır; ileri fazda ise aynı DOM snapshot verisi üzerinden daha gelişmiş tree edit distance, structural hashing veya template similarity algoritmalarına geçilebilir.

Ayrım:

MVP’deki bu feature “Basic DOM Structural Similarity”dir. İleri Faz belgesindeki “Advanced DOM Tree Similarity” ise daha ağır, algoritmik ve derin karşılaştırma yaklaşımıdır.

9.5 Logo / Favicon Similarity

Phishing siteleri çoğu zaman kullanıcıyı ikna etmek için markanın logosunu, renklerini veya faviconunu kopyalar. Bu nedenle logo/favicon similarity MVP Core içinde yer alır.

MVP’de ağır bir computer vision modeli yerine hafif pHash yaklaşımı yeterlidir. Referans logo veya favicon ile şüpheli siteden alınan favicon/screenshot görseli karşılaştırılır. pHash, görselin algısal parmak izini üretir. İki görselin hash değerleri birbirine yakınsa sistem bunu görsel taklit sinyali olarak kaydeder.

Bu sinyal tek başına nihai karar vermez; domain similarity, form detection ve OCR ile birlikte risk scoring içinde değerlendirilir.

9.6 OCR

Saldırganlar bazen marka adını veya kritik metni HTML'e yazmak yerine görsel içine gömer. Bu durumda klasik text scraping marka adını göremez. OCR, screenshot veya sayfa görsellerindeki metni okuyarak bu boşluğu kapatır.

MVP'de OCR'ın amacı gelişmiş belge analizi yapmak değildir. Temel hedef şunları yakalamaktır:

- Marka adı görselde geçiyor mu?
- "Giriş", "login", "doğrulama", "kampanya", "ödeme" gibi kritik kelimeler var mı?
- Görseldeki metin şüpheli siteyi markayla ilişkilendiriyor mu?

OCR sonucu `detection_signals` tablosunda ayrı sinyal olarak tutulur.

9.7 Form / Login Detection

Sahte sitelerde en kritik risklerden biri kullanıcı adı, şifre, telefon, kredi kartı veya ödeme bilgisinin toplanmasıdır. Bu nedenle form/login detection MVP Core kapsamındadır.

DOM üzerinde şu sinyaller aranır:

- `input type="password"`
- `input type="email"`
- Telefon, kart numarası veya ödeme alanı
- `form` elementi
- "Giriş Yap", "Login", "Sign In", "Devam Et" gibi submit butonu metinleri

Logo benzerliği orta düzeyde olsa bile login formu varsa risk ciddi şekilde artar. Bu yüzden form sinyali risk scoring içinde yüksek ağırlığa sahiptir.

9.8 Risk Scoring / Rule Engine

MVP'de karar mekanizması rule-based olmalıdır. Bunun nedeni açıklanabilirliktir. Sistem yalnızca "bu malicious" dememeli; hangi sinyaller nedeniyle bu kararı verdiğini de göstermelidir.

Bu noktada LLM karar verici olarak kullanılmaz. Nihai verdict rule engine tarafından üretilir. LLM yalnızca rule engine'in bir veya birkaç adımını destekleyebilir; örneğin sinyalleri insan-okunabilir özetleyebilir, analiste feedback verebilir veya takedown metni hazırlayabilir. Böylece karar açıklanabilir ve kontrol edilebilir kalır.

Önerilen skor mantığı:

```
score = (  
    domain_sim * 0.25 +  
    logo_sim * 0.20 +  
    dom_structural_score * 0.15 +  
    form_score * 0.20 +  
    ocr_score * 0.10 +  
    fingerprint_score * 0.10  
)  
  
if score >= 0.70:  
    verdict = "malicious"
```

```
elif score >= 0.40:
    verdict = "suspicious"
else:
    verdict = "clean"
```

HTML fingerprint MVP Plus olduğu için core aşamasında yoksa kalan sinyaller yeniden normalize edilebilir. Basic DOM structural similarity ise Core sinyal olarak kalır; çünkü DOM zaten crawler tarafından toplanmaktadır.

Örnek rule listesi:

Rule	Etki
Domain similarity > 0.85	+25
DNS aktif ve HTTP erişilebilir	+10
Basic DOM structural similarity yüksek	+15
Login/password formu bulundu	+20
Logo/favicon similarity yüksek	+25
OCR marka adını okudu	+15
Domain çok yeni kayıtlı	+10
HTML fingerprint daha önce görülmüş	+30
Human review false positive dedi	Risk düşür / pattern logla

Rule engine ileride büyüyebilir. MVP’de ise risk scoring modülünün içinde basit ve anlaşılır bir kural seti yeterlidir.

9.9 Human Review

Human review, otomatik kararların insan tarafından doğrulanmasını sağlar. Bu MVP için özellikle önemlidir çünkü sistemin yanlış alarm üretmesi mümkündür.

Human review ekranı ayrı React frontend ile değil, Scala Play Framework’ün Twirl template engine’i ile hazırlanacaktır. MVP için server-rendered basit ekran yeterlidir.

Ekranda gösterilecek alanlar:

- Şüpheli site screenshot’ı
- Referans domain/logo bilgisi
- Domain similarity skoru
- Logo/favicon similarity skoru
- Basic DOM structural similarity skoru
- OCR sonucu
- Form/login detection sonucu
- Toplam risk skoru
- Verdict
- Karar butonları: `confirmed`, `false_positive`, `needs_more_info`

Analistin kararı **reviews** tablosuna yazılır. İleri fazda bu veriler false positive azaltma veya model/rule iyileştirme için kullanılabilir.

9.10 Evidence Package ve Takedown Mock

Tespit edilen bir tehdidin aksiyona dönüşebilmesi için kanıt paketi gerekir. MVP’de gerçek takedown entegrasyonu zorunlu değildir; fakat takedown’a gidecek veri hazırlanmalıdır.

Evidence package içeriği:

Kanıt	Açıklama
Screenshot	Sahte sitenin görsel kanıtı
HTML archive	İçeriğin zaman damgalı kopyası
DOM snapshot	Form ve inputların teknik kanıtı
OCR sonucu	Görselde marka adı/kritik ifade kanıtı
Risk skoru	Kararın sayısal açıklaması
Review kararı	İnsan onayı

MVP’de takedown talebi loglanabilir. Zaman kalırsa tek bir hosting/registrar için API araştırması yapılabilir, ancak core demo için gerçek kapatma zorunlu değildir.

10. MVP Plus Modül Detayları

10.1 CT Log Feed

Certificate Transparency logları, yeni alınan SSL sertifikalarını izlemek için kullanılabilir. Saldırgan marka adını içeren bir domain için sertifika aldığında bu kaynak üzerinden aday domain yakalanabilir.

MVP Plus olmasının nedeni, core demo için manual URL ve permütasyonun yeterli olmasıdır. CT log eklenirse input kaynağı güçlenir.

10.2 WHOIS / Yeni Domain Feed

Yeni kayıtlı domainler phishing açısından önemlidir çünkü sahte siteler çoğu zaman kısa ömürlü domainlerle açılır. WHOIS veya yeni domain feed kaynakları marka benzerliğiyle filtrelenebilir.

Bu kaynak, geniş veri tarama ihtiyacı doğurduğu için MVP Plus olarak tutulur.

Not: WHOIS kaynağı ürün açısından değerlidir ve ücretsiz/yüksek hacimli yeni domain feed’leri MVP’ye katkı sağlayabilir. Ancak core demo için önce manual URL + permütasyon + DNS/HTTP + crawler + risk scoring akışının çalışması önceliklidir. Zaman kalırsa WHOIS feed aynı **candidates** tablosuna ek input kaynağı olarak bağlanabilir.

10.3 Şikayetvar Scraping

Kullanıcı şikayetleri teknik taramanın kaçırabileceği gerçek dünya sinyallerini verir. Bir kullanıcı sahte siteye düştüğünde şikayet metninde domain, telefon, IBAN veya marka adı paylaşabilir.

MVP’de Şikayetvar sınırlı ve opsiyonel input kaynağı olarak değerlendirilebilir. Yetişirse `candidates.source = "şikayetvar"` olarak pipeline’a bağlanır. Yetişmezse core demo manual/permutation üzerinden devam eder.

10.4 HTML Fingerprint ve Basit Recurrence

HTML fingerprint, sahte sitenin şablonunu veya phishing kit yapısını tanımaya yarar. Aynı saldırgan farklı domainler açsa bile HTML yapısı, favicon veya form düzeni benzer kalabilir.

Buradaki HTML fingerprint, MVP Core’daki Basic DOM Structural Similarity ile karıştırılmamalıdır. Basic DOM structural similarity mevcut adayın referans sayfaya temel düzeyde benzeyip benzemediğini ölçer. HTML fingerprint ise daha çok daha önce görülen/kapatılan phishing şablonlarının tekrar ortaya çıkmasını yakalamak için kullanılır.

MVP Plus kapsamında basit fingerprint saklama yapılabilir. Gelişmiş recurrence monitoring ve kampanya korelasyonu ise ileri fazda Threat Graph ile ele alınacaktır.

10.5 LLM Risk Özeti

LLM ana karar verici olmayacaktır. Karar domain similarity, logo/favicon similarity, OCR, form detection, basic DOM similarity ve rule-based scoring ile verilir. LLM yalnızca bu teknik sinyalleri insan-okunabilir kısa bir açıklamaya dönüştürür veya analiste feedback sağlar.

Örnek çıktı:

Bu domain resmi domaine yüksek oranda benziyor. Sayfada login formu bulunuyor ve favicon referans markaya benziyor. OCR sonucu marka adının görsel içinde kullanıldığını gösteriyor; bu nedenle vaka yüksek risklidir.

LLM özeti MVP Plus olarak tutulur çünkü demo için faydalıdır ama core karar motorunun çalışması için şart değildir.

11. Düşünülen Teknik Bileşenler

Bu bölüm nihai ürün mimarisi değil, MVP için düşünülen teknik bileşenleri özetler.

Teknik sınır notu: Bu bölüm nihai üretim mimarisi değildir. MVP’de teknoloji sayısını düşük tutmak için mesajlaşma ve dosya saklama katmanları PostgreSQL tabanlı tutulur. Ancak hem mesaj kuyruğu hem storage erişimi interface arkasından tasarlanır; ileride aynı interface’in Kafka veya harici nesne depolama implementasyonuna çevrilmesi mümkün olur.

Bileşen	MVP’de Düşünülen Teknoloji	Not
Backend / API	Scala Play Framework	Ana uygulama ve server-rendered ekranlar

Bileşen	MVP'de Düşünülen Teknoloji	Not
Template engine	Play Twirl Templates	React kullanılmayacak; human review ekranı Play template ile hazırlanacak
Actor / worker	Akka Actor	Crawler, analysis, risk scoring gibi işler aktör/worker mantığıyla ayrılacak
Veritabanı	PostgreSQL	JSONB ve outbox/queue yaklaşımı için
Mesaj akışı	PostgreSQL message queue / outbox implementasyonu	MVP'de Kafka kurulmadan actor/worker akışını yönetmek için; ileride aynı interface Kafka implementasyonuna çevrilebilir
Dosya depolama	PostgreSQL blob/large object veya ilgili storage extension	Screenshot, HTML, DOM ve evidence dosyaları için; ileride aynı storage interface arkasına S3 veya harici nesne depolama implementasyonu eklenebilir
Crawler	Browserless.io veya izole Docker/VM	Ana uygulama sunucusundan izole çalışmalı
Domain similarity	Levenshtein, Jaro-Winkler	Scala veya Python tarafında çalışabilir
Logo/favicon similarity	pHash / imagehash	MVP için hafif görsel benzerlik
Basic DOM structural similarity	DOM feature extraction	Form/input/button/tag dağılımı gibi basit yapısal sinyaller; advanced tree edit distance değil
OCR	Tesseract veya Google Vision API	MVP'de basit OCR yeterli
LLM özeti	OpenAI API veya muadili	MVP Plus; risk kararını açıklamak için
İleri teknik mimari alternatifi	Kafka implementasyonu	Feature değil, mesajlaşma interface'inin ilerideki olası production implementasyonudur

12. Data Flow — Uçtan Uca Akış

```

[Protected Entity / Asset tanımlanır]
↓
[Input kaynakları aday üretir]
  Core: manual URL + permütasyon
  Plus: CT log + WHOIS + Şikayetvar
↓
[candidates tablosuna yazılır]
↓
[Domain doğrulama worker/actor]
  DNS aktif mi?
  HTTP açılıyor mu?
  Domain similarity yeterli mi?
↓

```

```

[Uygun adaylar outbox/queue tablosuna alınır]
↓
[Crawler actor]
  Browserless/izole tarayıcı çağrılır
  Screenshot + DOM + HTML + favicon + metadata alınır
  PostgreSQL blob/storage extension'a kaydedilir
↓
[Analiz actor]
  Domain similarity
  Logo/favicon similarity
  Basic DOM structural similarity
  OCR
  Form/login detection
  HTML fingerprint (Plus)
↓
[Risk scoring actor]
  Rule-based skor
  clean / suspicious / malicious verdict
  LLM açıklaması (Plus)
↓
[Human review]
  confirmed / false_positive / needs_more_info
↓
[Case / Takedown mock]
  Evidence package hazırlanır
  Takedown talebi loglanır
  Recurrence için imza saklanır

```

12.1 Aşama Bazlı Veri Yazımı

Uçtan uca akışta her aşamanın veriyi nereye yazdığı aşağıdaki gibidir:

Aşama	Ne olur?	Kalıcı kayıt
Asset tanımlama	Korunan marka ve resmi domain/ subdomain bilgisi girilir	<code>entities</code> , <code>assets</code>
Candidate üretimi	Manual URL veya permütasyonla şüpheli domain oluşur	<code>candidates</code>
Ön doğrulama	DNS/HTTP ve ilk domain similarity kontrol edilir	<code>candidates.status</code> , <code>candidate_asset_matches</code>
Queue/outbox	Crawler veya analiz işi sıraya alınır	<code>outbox_jobs</code>
Crawl	Şüpheli site izole ortamda açılır ve dosyalar toplanır	<code>crawl_results</code> , PostgreSQL blob/ storage
Evidence saklama	Screenshot, HTML, DOM, favicon, OCR çıktısı storage referansı veya blob olarak tutulur	<code>evidence_files</code>
Analiz	Domain, logo/favicon, basic DOM structural similarity, OCR ve form sinyalleri hesaplanır	<code>detection_signals</code>
Risk kararı	Sinyaller ağırlıklandırılır ve verdict üretilir	<code>risk_scores</code>
Human review	Analist confirmed / false_positive / needs_more_info kararı verir	<code>reviews</code>
Case / takedown mock	Takedown için case açılır, kanıt paketi bağlanır, talep loglanır	<code>cases</code> , <code>evidence_files</code>

12.2 Outbox / Actor Mantığı

MVP’de Kafka kullanılmayacağı için modüller arası iş akışı PostgreSQL outbox/queue tablosu üzerinden yönetilebilir. Örneğin domain doğrulama başarılı olduğunda `outbox_jobs` tablosuna `crawl_candidate` işi yazılır. Crawler actor bu işi alır, siteyi tarar, sonucu yazdıktan sonra yeni bir `analyze_candidate` işi oluşturabilir.

Bu yaklaşım iki nedenle önemlidir:

1. MVP’de Kafka kurulmadan asenkron worker mantığı kurulabilir.
2. İleri fazda aynı job mantığı Kafka topic’lerine taşınabilir.

Yani MVP’deki outbox yapısı geçici bir çözüm olsa da, ileride event-driven mimariye geçişi kolaylaştıracak bir hazırlık olarak düşünülmelidir.

Bu yapı doğrudan PostgreSQL tablosuna bağımlı yazılmamalıdır. Uygulama içinde bir `MessageQueue` / `JobQueue` interface’i düşünülür; MVP’de bunun implementasyonu PostgreSQL message queue/outbox olur. İleri fazda ihtiyaç oluşursa aynı interface’in Kafka implementasyonu yazılarak producer/consumer yapısına geçilebilir. Böylece MVP’deki iş mantığı korunur, yalnızca mesaj taşıma altyapısı değişir.

13. MVP Dışında Bırakılanlar

Aşağıdaki konular MVP’de kodlanmayacaktır. Bu karar, scope’u yönetilebilir tutmak için verilmiştir:

- Kafka gibi üretim seviyesi mesajlaşma altyapısına geçiş
- Full Threat Graph / kampanya korelasyonu
- Multi-tenant müşteri izolasyonu
- Otomatik subdomain discovery
- İç sayfa crawling ve gelişmiş DOM tree similarity / derin site karşılaştırması
- Email security
- Sosyal medya ve reklam izleme
- Dark web izleme
- Gerçek çoklu takedown entegrasyonu
- Real-time kullanıcı koruması
- Deepfake / identity protection
- Self-improving model / Agentic SOC

Bu maddeler kaybolmayacak; ayrı İleri Faz belgesinde yol haritası olarak tutulacaktır.

Bu belge, feature analizindeki yeteneklerin MVP açısından açıklamalı şekilde ayrıştırılmış halidir. MVP kapsamı dışında kalan feature’lar ayrı İleri Faz belgesinde tutulmaktadır.